The Threat Environment: Attackers and Their Attacks

Reference:

Corporate & Network Security, Chapter 1

Raymond R. Panko

Agenda

- The threat environment—attackers and their attacks
- Basic security terminology
- Employee and ex-employee threats
- Traditional external attackers
- The criminal era and competitor threats
- Cyberwar and cyberterror

Copyright Pearson Prentice-Hall 2010

2.1.1 The Threat Environment…

- The world today is a dangerous place for corporations
- The Internet has given firms access to billions of customers and other business partners
- But the Internet has also given criminals access to hundreds of millions of corporations and far more individuals

Copyright Pearson Prentice-Hall 2010

The Environment

- Wireless transmission has brought new mobility but has also allowed attackers to enter corporations stealthily…
  - Bypassing firewalls designed to keep intruders from coming in through the Internet

Copyright Pearson Prentice-Hall 2010

The Threat Environment

- If companies are to be able to defend themselves, they need an understanding of the “threat environment”
- “Understanding the threat environment” is a fancy way of saying “know your enemy.”
- Unless you understand the threats you face, you cannot prepare for defense

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

The Threat Environment

The threat environment consists of the types of attackers and attacks that companies face

Copyright Pearson Prentice-Hall 2010

2.1.2 Basic Security Terminology

- **Security Goals**
  - Corporations and subgroups in corporations have security goals – conditions that the security staff wishes to achieve
  - Three common core goals are referred to as CIA:
    - Confidentiality
    - Integrity
    - Availability

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Security Goals**
  - Confidentiality
    - Confidentiality means that people cannot read sensitive information, either while it is on a computer or while it is traveling across a network.

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Security Goals**
  - Integrity
    - Integrity means that attackers cannot change or destroy information, either while it is on a computer or while it is traveling across a network.
    - Or, at least, if information is changed or destroyed, then the receiver can detect the change or restore destroyed data.

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Security Goals**
  - Availability
    - Availability means that people who are authorized to use information are not prevented from doing so

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Compromises**
  - Successful attacks
  - Also called incidents
  - Also called breaches (not breeches)

When a threat succeeds in causing harm to a business, this is called an incident, breach, or compromise

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

In terms of a business process model, threats push the business process away from meeting one or more of its goals

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- Companies try to deter incidents (of course), but they usually have to face several breaches every year

Response to incidents is a critical skill

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- CERT – Computer Emergency Response Team
- Sitting at SOC – Security Operation Center.
- They check any change occur inside network .
- Where some body has Broken Inn.
- They Used to Stop them create some solution for that Attck .
- Digital Fronsic is the way to respond to find and deal with these type of Situations.

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Countermeasures**
  - Tools used to thwart attacks
  - Also called safeguards, protections, and controls
  - Countermeasures can be technical, human, or a mixture of the two.
  - People Process and Technology .
  - People –Train them on policies and Procedures , when they are in office they not to use USB to transfer data .
  - Process- Define guidelines how to do particular Task.

Copyright Pearson Prentice-Hall 2010

- Sharing of Passwords are not allowed inside the organization .
- Technology – Network Access Controlloer NAC.
- Sits in the network , when some one use computer inside network , it will check MAC address , Login and Password and Has permission to use this network .
- Example of Access Control

Copyright Pearson Prentice-Hall 2010

- Identity and Access Management System.
- 20 000 Employess and 20 K user Id and Passwords too.
- Lot of ID s and Passwords
- Lot of People have authority to perform certain Task.
- CEO has certain Privilages to do certain task .
- Managers on 2nd tier has some other level privilege to perform certain task.

Copyright Pearson Prentice-Hall 2010

Basic Security Termiology

The goal of countermeasures is to keep business processes on track for meeting their business goals despite the presence of threats and actual compromises

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

- **Three Types Of Countermeasures**
  - Preventative: keep attacks from succeeding. Most controls are preventative
  - Detective: identify when a threat is attacking, and especially when it is succeeding. Fast detection can minimize damage
  - Corrective: get the business process back on track after a compromise.

Copyright Pearson Prentice-Hall 2010

Basic Security Terminology

The faster the business process can get back on track, the more likely the business process will be to meet its goals

Copyright Pearson Prentice-Hall 2010

2.1.3 The TJX Data Breach

- **The TJX Companies, Inc. (TJX)**
  - A group of more than 2,500 retail stores companies operating in the United States, Canada, England, Ireland, and several other countries
  - Does business under such names as TJ Maxx and Marshalls

Copyright Pearson Prentice-Hall 2010

The TJX Data Breach

- **Discovery**
  - On December 18, 2006, TJX detected "suspicious software" on its computer systems
  - Called in security experts who confirmed an intrusion and probable data loss
  - Notified law enforcement immediately
  - Only notified consumers a month later to get time to fix system and to allow law enforcement to investigate

Copyright Pearson Prentice-Hall 2010

The TJX Data Breach

- **Discovery**
  - Two waves of attacks, in 2005 and 2006
  - Company estimated that 45.7 million records with limited personal information included
  - Much more information was stolen on 455,000 of these customers

Copyright Pearson Prentice-Hall 2010

The TJX Data Breach

- **The Break-Ins**
  - Broke into poorly protected wireless networks in retail stores
  - Used this entry to break into central processing system in Massachusetts
  - Not detected despite long presence, 80 GB data exfiltration
  - Canadian privacy commission: poor encryption, keeping data that should not have been kept

Copyright Pearson Prentice-Hall 2010

The TJX Data Breach

- **The Payment Card Industry-Data Security Standard (PCI-DSS)**
  - Rules for companies that accept credit card purchases
  - If noncompliant, can lose the ability to process credit cards
  - 12 required control objectives
  - TJX knew it was not in compliance (later found to meet only 3 of 12 control objectives)
  - Visa gave an extension to TJX in 2005, subject to progress report in June 2006

Copyright Pearson Prentice-Hall 2010

The TJX Data Breach

- **The Fall-Out: Lawsuits and Investigations**
  - Settled with most banks and banking associations for $40.9 million to cover card reissuing and other costs
  - Visa levied $880,000 fine, which may later have been increased or decreased
  - Proposed settlement with consumers
  - Under investigation by U.S. Federal Trade Commission and 37 state attorneys general
  - TJX has prepared for damages of $256 million as of August 2007

Copyright Pearson Prentice-Hall 2010